

Security Information and Event Management (SIEM) Fundamentals

1. What is SIEM?

SIEM is a security solution that combines two technologies: **Security Information Management (SIM)** and **Security Event Management (SEM)**. It acts as a central system to collect, manage, and analyze security data from various sources in real-time.

2. How SIEM Works

- **Data Ingestion:** SIEM gathers raw data from devices like PCs, servers, and firewalls.
- **Normalization:** The system converts different raw data formats into a common, standardized format so the SIEM can understand it.
- **Detection & Alerting:** Security teams use this data to create rules and dashboards. When a potential threat is detected, the system sends an alert via email, text, or console notification.

3. Key Business Requirements

- **Log Aggregation:** It centralizes terabytes of data, providing the visibility needed to connect the dots between security incidents.
- **Contextualization:** It helps security teams filter through the noise by identifying the actors involved, the affected network parts, and the timing of events.
- **Compliance:** SIEM helps organizations meet regulatory standards like PCI DSS, HIPAA, and GDPR by providing real-time monitoring and automated audit reports.

4. Main Benefits

- **Centralized View:** It provides a single interface to view logs and events from the entire infrastructure.
- **Faster Incident Response:** By identifying threats early, IT staff can respond quickly and prevent full-scale security breaches.
- **Advanced Intelligence:** Modern SIEMs use behavioral analysis and AI to detect patterns and anomalies that humans might miss.

SOC Analysis Summary

Here is the simple summary of the analysis based on the SOC dashboard data:

- **Failed Logins (All Users):** The dashboard shows that the **Administrator** (and **administrator**) accounts had the most failed login attempts. You should also note that a service account named **sql-svc1** had failed attempts as well.
- **Failed Logins (Admin Users Only):** To find the total, I added up all the failed attempts listed for the administrator accounts.
 - **Total Answer:** 8

SOC Evolution and Defensive Approaches

Based on the provided information, here is the answer regarding SOC 2.0:

- **Statement:** SOC 2.0 follows a proactive defense approach.
- **Answer:** True
- **Reasoning:** SOC 2.0 emphasizes "pre-event preparedness" through vulnerability management, configuration management, and dynamic risk management. Additionally, it employs a forward-looking approach to threat research and complete situational awareness, which are crucial for its success.

MITRE ATT&CK Framework and Security Operations

The MITRE ATT&CK framework is an extensive, regularly updated resource that outlines the tactics, techniques, and procedures (TTPs) used by cyber threat actors.

Structure and Purpose

- **Structured Methodology:** The framework assists cybersecurity experts in understanding, identifying, and reacting to threats more proactively.
- **Matrices:** It comprises matrices tailored to various computing contexts, such as enterprise, mobile, or cloud systems, linking tactics (goals) and techniques (methods) to TTPs.

Key Use Cases in Security Operations

- **Detection and Response:** Supports SOCs in devising detection and response plans based on recognized TTPs.
- **Security Evaluation and Gap Analysis:** Organizations use the framework to identify security strengths and weaknesses, allowing them to prioritize security control investments.
- **SOC Maturity Assessment:** Enables organizations to assess SOC maturity by measuring their ability to detect, respond to, and mitigate various TTPs.
- **Threat Intelligence and Enrichment:** Provides a unified language to describe adversarial actions and provides context on TTPs, potential targets, and indicators of compromise (IOCs).

- **Behavioral Analytics:** Organizations can map TTPs to user and system behaviors to develop models that identify anomalous activities.
- **Red Teaming and Penetration Testing:** Provides a systematic way to replicate genuine attacker techniques to assess defensive capabilities.
- **Training and Education:** Acts as a comprehensive resource for training security professionals on the latest adversarial tactics and methods.

SIEM Use Case Development Summary

A SIEM use case is a fundamental part of a cybersecurity strategy, enabling the identification and detection of potential security incidents.

SIEM Use Case Development Lifecycle

To develop effective use cases, the following critical stages are followed:

- **Requirements:** Comprehend the purpose or necessity of the use case and pinpoint the specific scenario requiring an alert.
- **Data Points:** Identify where user accounts log in and gather logs from relevant sources such as Windows, Linux, servers, and applications.
- **Log Validation:** Verify that logs contain essential details like user, timestamp, source, destination, and application name.
- **Design and Implementation:** Define conditions using three primary parameters: Condition, Aggregation, and Priority.
- **Documentation:** Create Standard Operating Procedures (SOPs) that detail processes for analysts, including escalation matrices.
- **Onboarding:** Test the alert in a development stage to address gaps and reduce false positives before moving to production.
- **Periodic Update/Fine-tuning:** Continually refine and optimize rules based on analyst feedback and whitelisting to ensure accuracy.

Practical Examples

Example 1: MSBuild Started by Office Application

- **Risk:** Attackers exploit MSBuild to execute malicious source code within configuration or project files.
- **Severity:** High, as this behavior could indicate malicious script payload execution.
- **MITRE Mapping:** Defense Evasion (TA0005), Trusted Developer Utilities Proxy Execution (T1127/T1127.001), and Execution (TA0002).

Example 2: MSBuild Making Network Connections

- **Risk:** MSBuild is used to establish outbound communication with remote or potentially malicious IP addresses.
- **Severity:** Medium, as legitimate updates might trigger more false positives.
- **MITRE Mapping:** Execution (TA0002).

SOC Analysis: SQL Service Account Logins

Based on the provided SOC dashboard data, here is the information regarding the failed login attempts for the `sql-svc1` account:

- **Account Name:** `sql-svc1`
- **Associated Machine/Host:** PKI
- **Logon Type:** Network
- **Number of Failed Attempts:** 2

Answer: 2

SOC Lab Analysis Summary

Based on the dashboard data, here are the answers to your questions:

1. Failed Logins for `sql-svc1`

- **Count:** 2
- **Source:** Found in the "Failed logon attempts [All users]" table.

2. Logon Type for Disabled User (`anni`)

- **Logon Type:** 3
- **Context:** Found in the "Failed logon attempts [Disabled user]" table.

3. KQL Query for Admin Users

- **Query:** `*admin*`
- **Explanation:** Using wildcards (`*`) around the keyword "admin" ensures the search includes all variations like "Administrator" or "administrator".

Successful RDP Logons for Service Accounts

To monitor successful RDP logons related to service accounts, follow these steps in Kibana:

- **Setup:** Open the dashboard and click the "pencil/edit" icon. Click "Create visualization".
- **Filter Configuration:**

- Set the index pattern to `windows*`.
- Apply a filter for **Event ID 4624** (Successful Logon).
- Apply a filter for **Logon Type: RemoteInteractive**.
- **Visualization Configuration:**
 - Choose the **Table** option.
 - Under "Rows," add `user.name.keyword`, `host.hostname.keyword` (target machine), and `related.ip.keyword` (initiating IP).
 - Set **Count** as the metric.
- **Service Account Filter:** Use the KQL query `user.name: svc-*` to ensure only service accounts are included in the monitoring.
- **Finalize:** Click "Save and return" to add the visualization to the dashboard.

Monitoring Group Membership Changes (Administrators)

This visualization monitors users added to or removed from the local "Administrators" group.

Configuration Steps

- **Setup:** Open the dashboard, click the edit (pencil) icon, and select "Create visualization".
- **Filter Configuration:**
 - Set the index pattern to `windows*`.
 - Apply filters for Event ID 4732 (member added) and Event ID 4733 (member removed).
 - Apply a filter to include only the "Administrators" group.
- **Table Visualization:**
 - Select the "Table" option.
 - Set "Count" as the metric.
 - Add the following fields to the "Rows" configuration:
 - `winlog.event_data.MemberSid.keyword` (the user added/removed).
 - `group.name.keyword` (the group name).
 - `event.action.keyword` (action performed: added or removed).
 - `host.name.keyword` (the machine where the event occurred).

Timeframe & Persistence

- **Timeframe:** Use an absolute time range (e.g., from March 5th, 2023, to date) to ensure correct daily data bucketing.

- **Finalizing:** Click "Save and return" to add the visualization, then click the dashboard "Save" button to ensure all changes persist.

The SOC Alert Triaging Process

Alert triaging is the systematic process performed by SOC analysts to evaluate and prioritize security alerts to determine their threat level and impact.

The Ideal Triaging Process

The process follows these structured steps:

- **Initial Alert Review:** Review metadata, timestamps, IP addresses, and the specific rule that triggered the alert. Analyze associated logs to understand the context.
- **Alert Classification:** Classify the alert based on severity, impact, and urgency using the organization's predefined system.
- **Alert Correlation:** Cross-reference the alert with related events to identify patterns or indicators of compromise (IOCs). Query log management systems and leverage threat intelligence feeds.
- **Enrichment of Alert Data:** Gather additional context such as packet captures, file samples, or reconnaissance of affected systems for anomalies.
- **Risk Assessment:** Evaluate the potential impact on critical assets and the likelihood of successful attacks or lateral movement.
- **Contextual Analysis:** Consider the criticality of affected assets and evaluate if security controls failed or were evaded. Assess the impact on legal and regulatory compliance.
- **Incident Response Planning:** Document the alert details and assign incident response team members if the alert is significant.
- **Consultation with IT Operations:** Engage with IT teams to gather insights on recent maintenance or changes that could explain the alert, helping to rule out false positives.
- **Response Execution:** Based on the investigation, either take action to resolve a non-malicious event or proceed with incident response.
- **Escalation:** Notify higher-level teams if the alert involves critical system compromise, sophisticated techniques, or widespread impact. Provide a comprehensive summary and document all communications.
- **Continuous Monitoring & De-escalation:** Maintain coordination during the incident and de-escalate once the risk is mitigated and the situation is contained.

Importance of Escalation

Escalation ensures critical alerts receive prompt attention from decision-makers and specialized teams. It facilitates effective coordination among stakeholders, allowing the organization to

leverage the expertise necessary to mitigate high-level threats.

Threat Hunting — Simple Notes

What is Threat Hunting?

Threat hunting is **actively searching** through a network to find hidden threats that normal security tools miss.

- Normal security = wait for an alert → react
- Threat hunting = go look for threats **before** they cause damage

Dwell time = the time between a breach happening and it being detected. This is often **weeks or months** — threat hunting tries to reduce this.

Two Ways Threat Hunting is Used

Type	Description
Proactive	Hunt based on hypothesis and TTPs, before any incident
Reactive	Hunt across the network after a confirmed incident to find related threats

The Threat Hunting Process

1. **Identify assets** — what are the high-value targets?
2. **Analyze TTPs** — how would attackers go after them?
3. **Hunt** — look for artifacts and anomalies
4. **Use Threat Intelligence** — to guide the hunt

Threat Hunting Team Roles

Role	What They Do
Threat Hunter	Core hunter, searches for IoCs using tools and TTPs
Threat Intelligence Analyst	Collects data, understands threat landscape

Role	What They Do
Incident Responder	Handles containment and recovery when a threat is found
Forensics Expert	Deep technical analysis, malware analysis, DFIR
Data Analyst/Scientist	Finds patterns in large datasets using ML/statistics
Security Engineer	Designs secure infrastructure, supports hunting tools
Network Security Analyst	Monitors network traffic, spots anomalies
SOC Manager	Oversees the team, coordinates operations

When Should You Hunt?

- **New adversary/vulnerability discovered** → hunt immediately
- **New IoCs linked to a known attacker** → check if they're already in your network
- **Multiple network anomalies detected** → could be an attack, investigate
- **During an active incident** → hunt simultaneously with IR team
- **Regularly, always** → proactive hunting should be continuous

Threat Hunting & Incident Handling

They work **together**, not always separately:

- **Preparation** → set rules of engagement for hunters
- **Detection & Analysis** → hunters help confirm if IoCs = real incident
- **Containment/Recovery** → hunters may assist (depends on org policy)
- **Post-Incident** → hunters recommend security improvements

They can run **simultaneously** — IR team handles the known threat while hunters look for related hidden threats.

Threat Hunting & Risk Assessment

Risk assessment helps hunters focus on what matters most:

- **Crown jewels first** → hunt around the most critical assets
- **Know the TTPs** → build better hunting hypotheses

- **Find vulnerabilities** → look for signs of exploitation there
 - **Inform threat intelligence** → use risk data to pick relevant intel
 - **Improve IR plans** → anticipate breaches before they happen
-

Key Terms

Term	Meaning
Dwell Time	Time between breach and detection
TTP	Tactics, Techniques, and Procedures (how attackers operate)
IoC	Indicator of Compromise (evidence of an attack)
SIEM	Tool that collects and correlates security events
DFIR	Digital Forensics and Incident Response
PAW	Privileged Access Workstation
Hypothesis	An educated guess about how/where an attack might happen
